

The module's common thread: what is expected

Ten sessions, one case, one method. This document sets out what each group hands in on 17 September, how each piece is built session by session, and how all of it is graded.

Version 2, 8 September 2026 • aligned with the teaching proposal v1.6 • eight groups, two per subsidiary

What is handed in, at a glance

PIECE 1

One PDF file: the strategy note

Nine sub-sections, one per session from 1 to 9, three to five pages of text, tables and appendices not counted, in French or in English. This is the common thread itself: the document a chief executive reads. It opens the defence file.

PIECE 2

The file, in nine sessions

In whatever form and language the group chooses. Only two requirements: the **nine sessions kept separate**, and in each of them the **CISO's desk** (tutorial 1, in writing) and **the labs** of the session. Each session backs the sub-section with the same number.

PIECE 3

Proof of state

The dated export of the CISO Assistant instance, produced in session 10: what the tool contained at the moment of hand-in, readable outside the tool.

HOW THE THREE PIECES FIT TOGETHER

Sub-section *n* of the note makes a claim; session *n* of the file proves it; the export shows that the object exists in the tool. A claim in the note with nothing behind it in the file does not count; a piece in the file that the note says nothing about is wasted work. Nothing is reinvented from one session to the next: the session 2 mapping feeds the session 4 audit, which feeds the risk analysis, which feeds the statement of applicability.

The principle

For ten sessions, each student plays the **CISO of a MERIDIAN subsidiary**. MERIDIAN is a services group of 7,700 staff in four subsidiaries: Health, Logistics, Education, Territories. The group CISO is played by the instructor. Each working group handles **one subsidiary**, using its subsidiary file and the group reference file, and two groups work on each subsidiary from the same data: there is no single right answer, only decisions that are argued and traceable, or not. The lessons illustrate the concepts on a different company, TRAMONTANE, which is never the groups' case.

Mornings are for understanding, afternoons for producing, and grading bears on what was produced. The ten sessions form three blocks:

BLOCK 1 • 2 AND 3 SEPTEMBER • S1, S2

Foundations

Lay down the vocabulary and the raw material: what a security strategy is, and what the system to be protected is made of.

BLOCK 2 • 7 TO 10 SEPTEMBER • S3 TO S6

Assessing risk

Choose a framework, audit, assess risk, extend security to projects and third parties. Progress check at the end of the block.

BLOCK 3 • 14 TO 17 SEPTEMBER • S7 TO S10

Building and steering the system

Treat, formalise, steer, defend. The ISMS closes on itself and the file becomes presentable. The defence closes the module.

Piece 1: the strategy note, nine sub-sections

The note answers four questions and those alone: **where the subsidiary stands, where it must go, how it gets there, what it costs**. It is not a summary of the deliverables. Every afternoon ends with the same ritual: fifteen minutes in which the note gains its sub-section, drawn from what the day produced. Written in small touches, it makes visible the moment when a decision taken today contradicts one taken the day before.

SESSION	SUB-SECTION	WHAT IT ADDS TO THE TRAJECTORY	QUESTION SERVED
S1	Context and target governance	Who decides, through which bodies. Everything else refers back to it.	Where the subsidiary stands
S2	Critical assets	What matters most, and what the major risks will have to target.	Where the subsidiary stands
S3	Choice of framework	The yardstick chosen, what it costs, what it brings; the language in which the assets will be assessed.	Where it must go
S4	Current state	What the audit measured, what remains to be proven.	Where the subsidiary stands
S5	Major risks	The feared events that justify the effort.	Where it must go
S6	Third parties and projects	What the group demands of those it does not control.	How it gets there
S7	Risk treatment	What is decided, what stays open, what it costs.	How it gets there, what it costs
S8	ISMS scope	What the system covers, and what it excludes, with justification.	How it gets there
S9	Indicators and final version	How the committee will know whether the strategy holds. The note is reread, consistent, and no longer edited.	How we will know

THE THREE RULES OF THE DOCUMENT

Three to five pages of text in all: three is the target, five the ceiling; tables, diagrams and appendices do not count. **Nothing is deleted:** a sub-section that contradicts an earlier one amends it with a sentence of justification, it does not erase it. **Each sub-section connects to the previous ones:** that is the grading criterion, not the content. A note that recounts what was done is descriptive; a note that says what is decided, what stays open and what it costs is a strategy. The note is worth 3 of the 40 deliverable points; its final version is closed in session 9 and filed in session 10.

Piece 2: the file, in nine sessions

The form of the file is free: a single PDF, a folder tree, a shared space. So is the language, French or English, for the file and the note alike. Only two requirements, checked at hand-in: the **nine sessions are separate** and identifiable; each session contains the **CISO's desk**, the morning's tutorial 1, and **the labs** of the afternoon. The CISO's desk is **written**: each student answers, in one page at most, the question of the day transposed to their subsidiary, and closes with a recommendation to their management; it is the only individual mark running across the nine sessions. The labs produce the session's **deliverable**, D1 to D9, in the CISO Assistant tool, in a document, or in both; it feeds the sub-section of the note with the same number. The points in the last column are those of the deliverables scale: 40 in all, converted to a mark out of 20.

SESSION	CISO'S DESK (TUTORIAL 1): THE QUESTION OF THE DAY	DELIVERABLE OF THE LABS	SIZE AND LOCATION	POINTS
S1	What does a board actually need from its CISO?	D1 Scoping document and target governance: scope, stakes, stakeholders, constraints; three-level governance chart with bodies, frequencies and nature of decisions; charter, RACI matrix, coded directives, arbitration rules.	Two pages · document	4
S2	Why is every asset inventory wrong, and what do we do about it?	D2 Subsidiary mapping: business assets, supporting assets, availability, integrity, confidentiality and traceability needs, cross-subsidiary dependencies, justified top 5 of critical assets, acknowledged gaps, update process.	Instance and file	5
S3	Are we in scope for NIS2, and on what grounds?	D3 Business case note: regulatory qualification, argued choice of framework, options set aside, mapping matrix, workload estimate.	Two pages plus the export	4
S4	What does an ISO 27001 certificate actually prove to a customer?	D4 Initial audit report: compliance rate by theme, qualified and prioritised findings, gaps tied back to the framework, one-page summary for management, scoping of the authorisation decision.	Document backed by the assessment in the instance	4
S5	Who sets risk appetite, and how is it written down?	D5 EBIOS RM workshops 1 and 2: security baseline, justified severity and likelihood scales, six rated feared events, three risk origin / target objective pairs retained out of five candidates, with reasons for those set aside.	Instance and a half-page note	3
S6	A supply chain attack we should learn from, and the clause that would have helped.	D6 Ecosystem, third parties and project: rated stakeholders, two strategic scenarios including one through a supplier, requirements and monitoring sheet for the critical third party, project security integration sheet.	Instance and document	7
S7	How do you put a number on the cost of doing nothing?	D7 Risk treatment: one rated operational scenario, risk register on both axes with its matrix, acceptance criteria, prioritised treatment plan costed over three years, residual risks and formal acceptances.	Instance and document	5
S8	Should we go for certification? Make the business case.	D8 Statement of applicability: ISMS scope, controls retained, each exclusion justified in writing, coverage rate, remaining gaps.	Instance and document	2
S9	KPI or KRI: what goes on the board dashboard?	D9 Policy, documents, indicators: security policy on the imposed template, one procedure, one quick-reaction sheet, five to eight indicators with formula, source, threshold, frequency and recipient.	Document	3
S1 to S9	Strategy note, piece 1			3
Deliverables and strategy note, out of 40 points				40

WHAT IS NOT IN THE FILE

The costed multi-year roadmap from session 1 is kept by the group but is not part of the hand-in: it is the subject of the resit. The scoping document, on the other hand, stays in session 1 of the file as evidence of governance.

MARKING SCALE FOR THE CISO'S DESK, WRITTEN	WHAT IS ASSESSED	POINTS
Accuracy and relevance	The content is correct, sourced, and transposed to the subsidiary: the student says what the question means in practice for it	4
CISO stance	One page, kept to length and structured, with an explicit recommendation addressed to management	3
Writing	Readable by a non-technical executive, in the chosen language, acronyms spelled out, no jargon and no copying from the course	3
CISO's desk		10

Piece 3 and session 10: hand-in and defence

Session 10 creates nothing: it checks, consolidates, hands in and defends. Three readers must find their way through what is handed in without the authors: the management that decides, the auditor who verifies, the successor who takes over.

08:30 to 09:15	Filing of documents and evidence in the tool, dated export of the full file, final touches to the slides.
09:15 to 12:30	Defences of groups 1 to 5, thirty minutes each, break at 10:45.
13:30 to 15:00	Defences of groups 6 to 8.
15:00 to 15:45	Module synthesis: what the eight files have in common, what sets them apart, the decisions that diverged most between two groups on the same subsidiary.
15:45 to 16:30	Round table, individual feedback and hand-over of the exports to each student.

Each group has **thirty minutes**: eighteen to present, twelve for questions. The setting is an **executive committee**, not a technical jury: the audience is assumed to know nothing about security and to have a budget to sign. The group presents its diagnosis, its major risks, its strategy, its costed plan and what it asks management to accept. The strategy note opens the file handed to the panel; the export from the tool is its supporting evidence. The questions must include **one individual question per student**, on a part of the work they have declared as their own.

MARKING SCALE FOR THE DEFENCE	WHAT IS ASSESSED	POINTS
Structure and clarity	Main message identifiable within the first minute, time kept, legible slides	6
Relevance to management	The group speaks at the decision-maker's level: the alternative, the cost of inaction, what it asks to have signed	8
Command of the substance	Correct answers on the facts and on the reasons; every member can defend their own part and place the others'	10
Evidence file	Strategy note, file in nine sessions and export: complete, ordered, usable as is by a third party	6
Defence		30

THE LIMIT TO STATE TO THE COMMITTEE BEFORE IT STATES IT

A file proves the method, never security itself. Misconfigured servers do not care how tidy the binder is. This has been the module's constant lesson since the session 4 audit report, and it is the one a panel expects to hear from the group.

The module's grading scheme

All marks are out of 20. One coefficient point is worth 10% of the module mark.

COMPONENT	FORMAT	SCOPE	COEFFICIENT
The CISO's desk, written	One page per session, in the language of the file, sessions 1 to 9; 10 points converted to a mark out of 20	Individual	1
Continuous assessment, nine quizzes	Thirteen to fifteen questions, 45 minutes, sessions 1 to 9; each quiz entered separately with a coefficient of 2/9	Individual	2
Deliverables D1 to D9 and strategy note	Output assessed in the evening on the exported objects and the documents; 40 points converted to a mark out of 20	Group, individualised	4
Final defence	Eighteen minutes plus twelve of questions; 30 points converted to a mark out of 20	Group, individualised	3
Module mark = (1 x CISO's desk + 2 x quizzes + 4 x deliverables + 3 x defence) / 10			10

INDIVIDUALISING A GROUP MARK

The collective share, deliverables and defence, carries an **individual coefficient on four steps: 0.85 · 0.95 · 1.05 · 1.15**, based on two elements of equal weight: named traceability in the tool, where every object created carries an owner, and the individual question at the defence. The coefficients within a group average 1: what one student gains, the other loses; and the result stays capped at the grid maximum. Each student receives their coefficient with its step and the two reasons behind it.

CHECKPOINT	WHEN	CONTENT AND FOLLOW-UP
Status check	End of block 1 · S2	Check that all eight groups have a usable scope and mapping. Not graded. A group in difficulty receives a completed mapping during the break.
Mid-course progress check	End of block 2 · S6	Formal report sent to the school: average of quizzes 1 to 6, deliverables D1 to D6 against their scale, individual appraisal. This is the point where a lapse can still be caught up.
Final assessment	S10	Defence, evidence file and consolidated mark. Individual feedback the same day.